



Ecole Supérieure
d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE



ETHICAL HACKING & DEFENSE





Certified Ethical Hacker

PRÉPARÉ PAR:
SEBBAR ANASS

EC-COUNCIL | ACADEMIA
PARTNER

Année universitaire: 2024-2025

1



LO#04: Explain Ethical Hacking Concepts and Scope

2

What is Ethical Hacking?



- Ethical hacking involves the use of hacking tools, tricks, and techniques to **identify vulnerabilities** and ensure system security


- It focuses on simulating the techniques used by attackers to **verify the existence of exploitable vulnerabilities** in a system's security


- Ethical hackers perform security assessments for an organization **with the permission of concerned authorities**



3

Why Ethical Hacking is Necessary



To beat a hacker, you need to think like one!

Ethical hacking is necessary as it **allows for counter attacks against malicious hackers** through anticipating the methods used to break into the system

Reasons why organizations recruit ethical hackers

To prevent hackers from gaining access to the organization's information systems	To provide adequate preventive measures in order to avoid security breaches
To uncover vulnerabilities in systems and explore their potential as a security risk	To help safeguard customer data
To analyze and strengthen an organization's security posture, including policies, network protection infrastructure, and end-user practices	To enhance security awareness at all levels in a business

4

Why Ethical Hacking is Necessary (Cont'd)



Ethical Hackers Try to Answer the Following Questions

- 1 What can an intruder see on the **target system**? (Reconnaissance and Scanning phases)
- 2 What can an **intruder do** with that information? (Gaining Access and Maintaining Access phases)
- 3 Does anyone at the target organization **notice the intruders' attempts** or successes? (Reconnaissance and Covering Tracks phases)
- 4 Are all **components of the information system** adequately protected, updated, and patched?
- 5 How much time, effort, and money are required to obtain **adequate protection**?
- 6 Are the **information security measures** in compliance with legal and industry standards?

5

Scope and Limitations of Ethical Hacking



Scope

- Ethical hacking is a crucial component of **risk assessment, auditing, counter fraud**, and information systems security **best practices**
- It is used to **identify risks** and highlight **remedial actions**. It also reduces ICT costs by resolving vulnerabilities



Limitations

- Unless the businesses already know what they are looking for and why they are **hiring an outside vendor to hack systems** in the first place, chances are there would not be much to gain from the experience
- An ethical hacker can only help the organization to better **understand its security system**; it is up to the organization to **place the right safeguards** on the network



6

Skills of an Ethical Hacker



1 Technical Skills

- In-depth **knowledge of major operating environments** such as Windows, Unix, Linux, and Macintosh
- In-depth **knowledge of networking** concepts, technologies, and related hardware and software
- A **computer expert** adept at technical domains
- **Knowledgeable about security areas** and related issues
- **"High technical" knowledge** for launching sophisticated attacks

2 Non-Technical Skills

- The **ability to learn** and adopt new technologies quickly
- **Strong work ethics** and good problem solving and communication skills
- Committed to the **organization's security policies**
- An awareness of **local standards and laws**



7

LO#05: Summarize the Techniques used in Information Security Controls

8

Information Assurance (IA)



- IA refers to the assurance that the **integrity, availability, confidentiality, and authenticity** of information and information systems is protected during the usage, processing, storage, and transmission of information
- Some of the processes that help in achieving information assurance include:

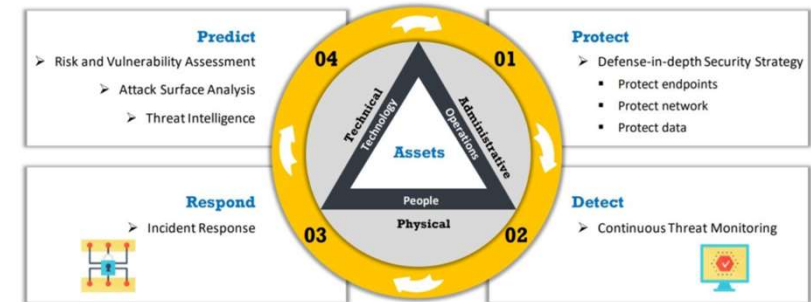
- | | |
|--|---|
| 1 Developing local policy, process, and guidance | 5 Creating plans for identified resource requirements |
| 2 Designing network and user authentication strategies | 6 Applying appropriate information assurance controls |
| 3 Identifying network vulnerabilities and threats | 7 Performing certification and accreditation |
| 4 Identifying problem and resource requirements | 8 Providing information assurance training |

9

Continual/Adaptive Security Strategy



- Organizations should adopt **adaptive security strategy**, which involves implementing all the four network security approaches
- The adaptive security strategy consists of four security activities corresponding to each security approach

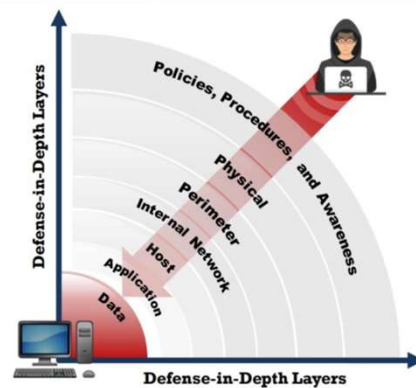


10

Defense-in-Depth



- Defense-in-depth is a security strategy in which **several protection layers** are placed throughout an information system
- It helps to **prevent direct attacks** against the system and its data because a break in one layer only leads the attacker to the next layer



11

What is Risk?



- Risk refers to the degree of **uncertainty** or expectation that an adverse event may cause damage to the system
- Risks are categorized into different levels according to their estimated impact on the system
- A risk matrix is used to scale risk by considering the **probability, likelihood, and consequence or impact** of the risk

Risk Levels

Risk Level	Action
Extreme or High	- Immediate measures should be taken to combat risk - Identify and impose controls to reduce risk to a reasonably low level
Medium	- No urgent action is required - Implement controls as soon as possible to reduce risk to a reasonably low level
Low	Take preventive steps to mitigate the effects of risk

Risk Matrix

Probability		Consequences				
		Insignificant	Minor	Moderate	Major	Severe
Likelihood	81 - 100%	Very High Probability	Low	Medium	High	Extreme
	61 - 80%	High Probability	Low	Medium	High	Extreme
	41 - 60%	Equal Probability	Low	Medium	Medium	High
	21 - 40%	Low Probability	Low	Low	Medium	Medium
	1 - 20%	Very Low Probability	Low	Low	Medium	Medium

Note: This is an example of a risk matrix. Organizations need to create their own risk matrix based on their business needs

12

Risk Management



- Risk management is the process of **reducing and maintaining risk at an acceptable level** by means of a well-defined and actively employed security program

Risk Management Phases

Risk Identification	Identifies the sources , causes, consequences, and other details of the internal and external risks affecting the security of the organization
Risk Assessment	Assesses the organization's risk and provides an estimate of the likelihood and impact of the risk
Risk Treatment	Selects and implements appropriate controls for the identified risks
Risk Tracking	Ensures appropriate controls are implemented to handle known risks and calculates the chances of a new risk occurring
Risk Review	Evaluates the performance of the implemented risk management strategies

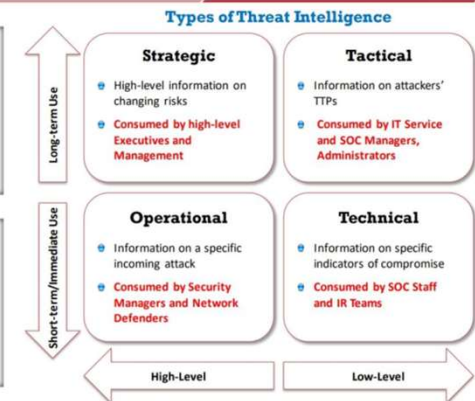
13

Cyber Threat Intelligence



- Cyber Threat Intelligence (CTI) is defined as the **collection and analysis of information** about threats and adversaries and the drawing of patterns that provide the ability to make knowledgeable decisions for preparedness, prevention, and response actions against various cyber-attacks

- Cyber threat intelligence helps the organization to **identify and mitigate various business risks** by converting unknown threats into known threats; it helps in implementing various advanced and proactive defense strategies



14

Threat Intelligence Lifecycle



5. Dissemination and Integration

- Deliver the intelligence to the intended consumers at different levels
 - Strategic (High-Level Business Strategies)
 - Tactical (TTPs)
 - Operational (Specific Threats)
 - Technical (IoCs)

4. Analysis and Production

- Combine information from phase 3 into a single entity
- Include facts, findings, and forecasts
- Analysis should be
 - Objective
 - Timely
 - Accurate
 - Actionable
- Perform confidence-based analysis



1. Planning and Direction

- Define intelligence requirements
- Make a collection plan
- Form an intelligence team
- Send requests for data collection
- Plan and set requirements for other phases

2. Collection

- Collect required data that satisfies intelligence goals
- Collection sources include
 - OSINT
 - HUMINT
 - IMINT
 - MASINT, etc.

3. Processing and Exploitation

- Process raw data for exploitation
- Convert processed data into usable format for data analysis

15

Threat Modeling



Threat modeling is a **risk assessment approach** for analyzing the security of an application by capturing, organizing, and analyzing all the information that affects the security of an application

Threat Modeling Process

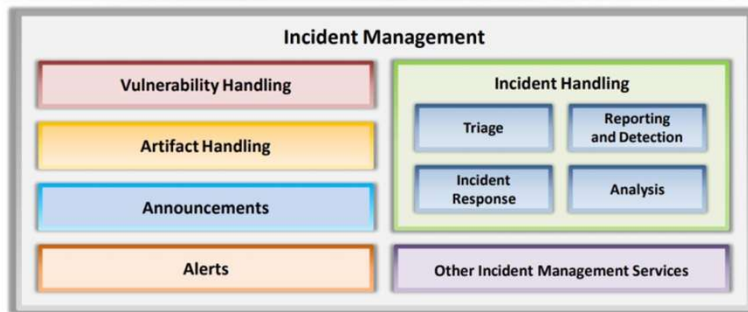
01	Identify Security Objectives	Helps to determine how much effort needs to be put toward subsequent steps
02	Application Overview	Identify the components, data flows , and trust boundaries
03	Decompose the Application	Helps to find more relevant and more detailed threats
04	Identify Threats	Identify threats relevant to the control scenario and context using the information obtained in steps 2 and 3
05	Identify Vulnerabilities	Identify weaknesses related to the threats found using vulnerability categories

16

Incident Management



- Incident management is a set of defined processes to **identify, analyze, prioritize, and resolve security incidents** to restore normal service operations as quickly as possible and prevent future recurrence of the incident



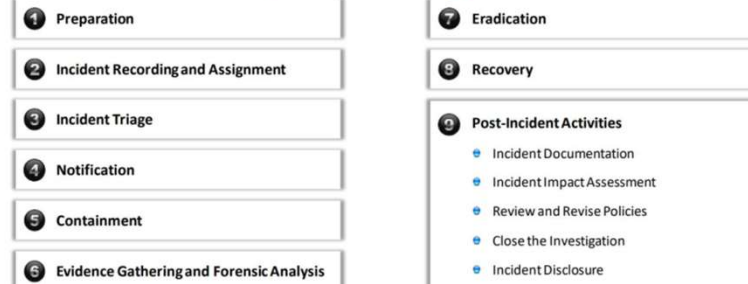
17

Incident Handling and Response



- Incident handling and response (IH&R) is the **process of taking organized and careful steps** when reacting to a security incident or cyberattack

Steps involved in the IH&R process:



18

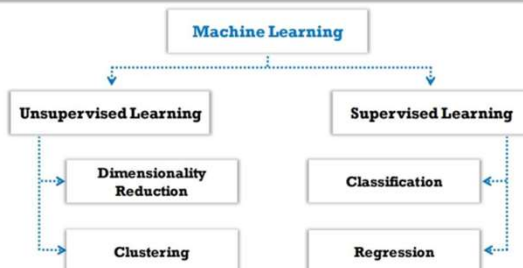
Role of AI and ML in Cyber Security



- Machine learning (ML) and artificial intelligence (AI) are now vastly used across various industries and applications due to the **increase in computing power, data collection, and storage capabilities**
- ML is an **unsupervised self-learning system** that is used to define what the normal network looks like, along with its devices, and then to backtrack and **report any deviations or anomalies** in real-time
- AI and ML in cyber security helps in **identifying new exploits and weaknesses**, which can then be easily analyzed to mitigate further attacks

ML classification techniques:

- Supervised learning makes use of algorithms that input a **set of labeled training data**, with the aim of learning the differences between the labels
- Unsupervised learning makes use of algorithms that input **unlabeled training data**, with the aim of deducing all categories by itself



19

How Do AI and ML Prevent Cyber Attacks?



20



LO#06: Explain the Importance of Applicable Security Laws and Standards

21

Payment Card Industry Data Security Standard (PCI DSS)



- The Payment Card Industry Data Security Standard (PCI DSS) is a proprietary **information security standard for organizations** that handle cardholder information for major debit, credit, prepaid, e-purse, ATM, and POS cards
- PCI DSS **applies to all entities involved in payment card processing** — including merchants, processors, acquirers, issuers, and service providers, as well as all other entities that store, process, or transmit cardholder data

PCI Data Security Standard — High Level Overview



22

ISO/IEC 27001:2013



- ISO/IEC 27001:2013 specifies the requirements for **establishing, implementing, maintaining**, and continually improving an **information security management system** within the context of the organization
- It is intended to be suitable for several different types of use, including:

- | | | | |
|---|--|---|---|
| 1 | Use within organizations to formulate security requirements and objectives | 5 | Identification and clarification of existing information security management processes |
| 2 | Use within organizations to ensure that security risks are cost-effectively managed | 6 | Use by organization management to determine the status of information security management activities |
| 3 | Use within organizations to ensure compliance with laws and regulations | 7 | Implementation of business-enabling information security |
| 4 | Definition of new information security management processes | 8 | Use by organizations to provide relevant information about information security to customers |
- <https://www.iso.org>

23

Health Insurance Portability and Accountability Act (HIPAA)



HIPAA's Administrative Simplification Statute and Rules

- | | |
|--|---|
| Electronic Transaction and Code Set Standards | Requires every provider who does business electronically to use the same health care transactions, code sets, and identifiers |
| Privacy Rule | Provides federal protections for the personal health information held by covered entities and gives patients an array of rights with respect to that information |
| Security Rule | Specifies a series of administrative, physical, and technical safeguards for covered entities to use to ensure the confidentiality, integrity, and availability of electronically protected health information |
| National Identifier Requirements | Requires that health care providers, health plans, and employers have standard national numbers that identify them attached to standard transactions |
| Enforcement Rule | Provides the standards for enforcing all the Administration Simplification Rules |
- <https://www.hhs.gov>

24

General Data Protection Regulation (GDPR)



- GDPR regulation was put into effect on May 25, 2018 and one of the **most stringent privacy and security laws globally**
- The GDPR will **levy harsh fines** against those who violate its privacy and security standards, with penalties reaching tens of millions of euros

GDPR Data Protection Principles

- Lawfulness, fairness, and transparency:** Processing must be lawful, fair, and transparent to the data subject
- Purpose limitation:** You must process data for the legitimate purposes specified explicitly to the data subject when you collected it
- Data minimization:** You should collect and process only as much data as necessary for the purposes specified
- Accuracy:** You must keep personal data accurate and up to date
- Storage limitation:** You may only store personally identifying data for as long as necessary for the specified purpose
- Integrity and confidentiality:** Processing must be done in such a way as to ensure appropriate security, integrity, and confidentiality (e.g., by using encryption)
- Accountability:** The data controller is responsible for demonstrating GDPR compliance with all these principles

<https://gdpr.eu>

25

Module 2

Footprinting and Reconnaissance

26



LEARNING OBJECTIVES

- | | |
|---|--|
| LO#01: Explain Footprinting Concepts | LO#07: Use Different Techniques for Whois Footprinting |
| LO#02: Demonstrate Footprinting through Search Engines | LO#08: Use Different Techniques for DNS Footprinting |
| LO#03: Demonstrate Footprinting through Web Services | LO#09: Use Different Techniques for Network Footprinting |
| LO#04: Demonstrate Footprinting through Social Networking Sites | LO#10: Demonstrate Footprinting through Social Engineering |
| LO#05: Use Different Techniques for Website Footprinting | LO#11: Use Various Footprinting Tools |
| LO#06: Use Different Techniques for Email Footprinting | LO#12: Explain Footprinting Countermeasures |

27



LO#01: Explain Footprinting Concepts

28

What is Footprinting?



Footprinting is the first step of any attack on information systems in which an attacker **collects information about a target network** to identify various ways to intrude into the system

Types of Footprinting

Passive Footprinting

Gathering information about the target **without direct interaction**

Active Footprinting

Gathering information about the target **with direct interaction**

29

Information Obtained in Footprinting



Organization information

- Employee details
- Telephone numbers
- Branch and location details
- Background of the organization
- Web technologies
- News articles, press releases, and related documents



Network information

- Domain and sub-domains
- Network blocks
- Network topology, trusted routers, and firewalls
- IP addresses of the reachable systems
- Whois records
- DNS records



System information

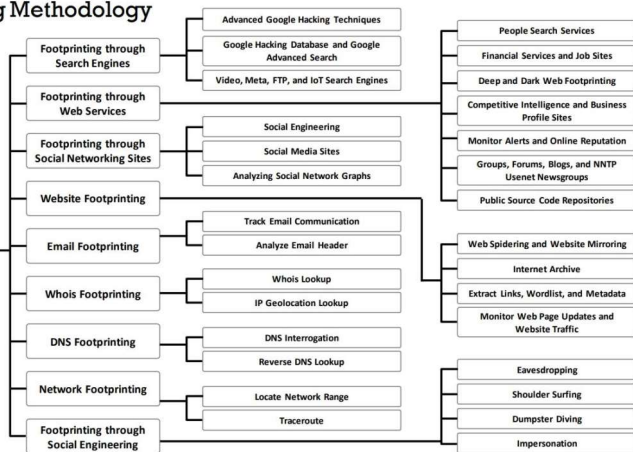
- Web server OS
- Location of web servers
- Publicly available email addresses
- Username and passwords

30

Footprinting Methodology



Footprinting Techniques



31

LO#02: Demonstrate Footprinting through Search Engines

32

Footprinting through Search Engines



- Attackers use search engines to **extract information about a target**, such as employed technology platforms, employee details, login pages, and intranet portals, which help the attacker to perform social engineering and other types of advanced system attacks
- Major search engines:
- Attackers can use **advanced search operators** available with these search engines and create complex queries to find, filter, and sort specific information about the target
- Search engines are also used to find other sources of **publically accessible information resources**, e.g., you can type "top job portals" to find major job portals that provide critical information about the target organization

33

Footprinting Using Advanced Google Hacking Techniques



- Google hacking refers to the use of advanced Google search operators for **creating complex search queries** to extract sensitive or hidden information that helps attackers **find vulnerable targets**

Popular Google advanced search operators

Search Operator	Purpose	Search Operator	Purpose
[cache:]	Displays the web pages stored in the Google cache	[allintitle:]	Restricts the results to those websites containing all the search keywords in the title
[link:]	Lists web pages that have links to the specified web page	[intitle:]	Restricts the results to documents containing the search keyword in the title
[related:]	Lists web pages that are similar to the specified web page	[allinurl:]	Restricts the results to those containing all the search keywords in the URL
[info:]	Presents some information that Google has about a particular web page	[inurl:]	Restricts the results to documents containing the search keyword in the URL
[site:]	Restricts the results to those websites in the given domain	[location:]	Finds information for a specific location

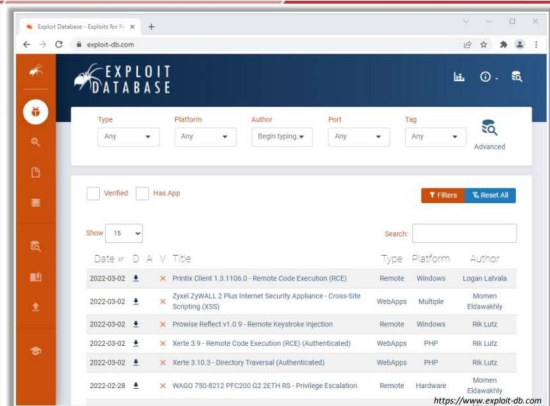
34

Google Hacking Database



- The Google Hacking Database (GHDB) is an authoritative source for **querying the ever-widening reach of the Google search engine**
- Attackers use **Google dorks** in Google advanced search operators to extract sensitive information about their target, such as vulnerable servers, error messages, sensitive files, login pages, and websites

**EXPLOIT
DATABASE**



35

VPN Footprinting through Google Hacking Database



Google Dork	Description
inurl:"/sslvpn_login.shtml" intitle:"User Authentication" "WatchGuard Technologies"	Finds pages containing login portals
inurl:/sslvpn/Login/Login	Finds VPN login portals
site:vpn.*.*/intitle:"login"	Finds Fortinet VPN login pages
intext:Please Login SSL VPN inurl:remote/login	Finds Fortinet VPN login pages
intext:FortiClient	Retrieves various VPN login pages
site:vpn.*.*/intext:"login" intitle:"login"	Retrieves juicy information and sensitive directories
intitle:"index of" /etc/openvpn/	Finds OpenVPN static keys
"-----BEGIN OpenVPN Static key V1-----" ext:key	Retrieves juicy information about the vpn-config file
intitle:"index of" "vpn-config.*"	Finds OpenVPN configuration files, some certificates, and keys
Index of / *.ovpn	Finds Netscaler and Citrix Gateway VPN login portals
inurl:"/vpn/tmindex.html" vpn	Finds Cisco ASA login web pages
intitle:"SSL VPN Service" + intext:"Your system administrator provided the following information to help understand and remedy the security conditions:"	

<https://www.exploit-db.com>

36

CEH
Certified Ethical Hacker

CEH
Certified Ethical Hacker

CEH

CEH
Certified Ethical Hacker

- CEH**
Certified Ethical Hacker

CEH
Certified Ethical Hacker

CEH
Certified Ethical Hacker

CEH
Certified Ethical Hacker

- CEH**
Certified Ethical Hacker



Gathering Information from LinkedIn



- Attackers use **theHarvester** tool to perform enumeration on LinkedIn and find employees of the target company along with their job titles
- Attackers can use this information to gather more information, such as **current location** and **educational qualifications**, and perform social engineering or other kinds of attacks

```

Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ theHarvester -d microsoft -l 200 -b linkedin
theHarvester 4.0.0
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com

[*] Target: microsoft
Searching 100 results.

Ahmed Zayed
Ahmed Zayed - General Manager
Alex Simons
Alex Simons - Senior Program Manager
Andrey Praskurin - Corporate Vice President of Engineering
Andrey Praskurin - Chief Technology Officer
Brooke Mikalacki - Business Applications Sales Executive
Charles Lamanna - Corporate Vice President
Charles Lamanna - Corporate Vice President
Charlie Hall
Charlie Hall - Microsoft Technical Training
Cheri Chevalier
Chris Pratley - Corporate Vice President
Christine Goyat - Director Corporate Affairs
Cindy Davison - National Azure Director
Dan McElroy - Datacenter Technician
David Reuschlein
David Reuschlein - Microsoft 365 for Education Country Lead
David Reuschlein

```

41

Harvesting Email Lists



- Gathering email addresses related to the target organization acts as an **important attack vector during the later phases of hacking**
- Attackers use automated tools such as **theHarvester** and **Email Spider** to collect publicly available email addresses of the target organization that helps them perform social engineering and brute-force attacks

```

Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ theHarvester -d microsoft.com -l 200 -b baidu
theHarvester 4.0.0
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com

[*] Target: microsoft.com
Searching Baidu.

[*] Searching Baidu.
[*] No IPs found.
[*] Emails found: 1
[*] Email: cmartorella@microsoft.com
[*] Hosts found: 5
[*] Hosts:
apps.dev.microsoft.com:40.126.29.20, 40.126.29.21, 40.126.29.0, 40.126.2
9.2, 40.126.29.22, 40.126.29.23, 40.126.29.1
redeem.microsoft.com:23.219.127.195
signup.microsoft.com:13.107.246.41, 13.107.213.41
support.microsoft.com:23.193.120.116
www.microsoft.com:23.46.201.6
[attacker@parrot:~]$

```

42

Footprinting through Job Sites



A **company's infrastructure details** can be gathered from job postings

Server and Network Administrator
 Whitney Museum of American Art, New York, NY · 10 hours ago

Responsibilities:

- Administration of three VMware ESX hosts, including configuration, installation, and maintenance of several virtual servers, routine maintenance, patches, and software updates, maintaining VM backups and snapshots, and overall support of VMware environment.
- Managing our on-premises Exchange 2010 server for 400 users, creating mailboxes, resources, public folders, and server-side rules, creating mail policies, implementing patches and updates, and monitoring database size and server status.
- Administration and configuration of Citrix and NetScaler environment, deploying Citrix updates, fixes and general maintenance, deploying and updating applications on Citrix, and ensuring security for remote connectivity.
- Manage transition to and administration of Office365.
- Manage Active Directory structure.
- Work closely with the storage and network manager to maximize efficient use of resources.
- Assist in day to day Help Desk and end user support tasks.
- Respond to emergency technology issues as they occur.

Qualifications and Skills:

- 10+ years professional work experience and skills in network administration, Windows Server OS, VMware, Exchange 2010, Citrix NetScaler Gateway/StoreFront/NetApp is required.
- VMware Certified Professional (VCP), VMware Certified Advanced Professional (VCAP), Citrix CCA-V, and/or CCP-V certification is highly desirable.
- Experience with migration to Microsoft 365, SharePoint, ATP, and Intune.
- Excellent knowledge of best practices around management, control, and monitoring of server infrastructure.
- Exceptional critical thinking and problem-solving ability.
- Strong interpersonal skills to assist non-technical individuals with complex technical issues.

Look for these:

- Job requirements
- Employees' profiles
- Hardware information
- Software information

- Attackers use the technical information obtained through job sites, such as Dice, LinkedIn, and Simply Hired, to **detect underlying vulnerabilities in the target IT infrastructure**



43

Deep and Dark Web Footprinting



- Deep web**
- It consists of web pages and contents that are **hidden and unindexed** and cannot be located using traditional web browsers and search engines
- It can be accessed by **search engines** like Tor Browser and The WWW Virtual Library

- Dark web or Darknet**
- It is the subset of the deep web that enables anyone to **navigate anonymously** without being traced
- It can be accessed by **browsers**, such as TOR Browser, Freenet, GUNet, I2P, and Retroshare

- Attackers use deep and dark web searching tools, such as **Tor Browser** and **ExoneraTor**, to **gather confidential information about the target**, including credit card details, passport information, identification card details, medical records, social media accounts, Social Security Numbers (SSNs), etc.

TOR Browser

It is used to access the deep and dark web where it acts as a **default VPN** for the user and bounces the network IP address through several servers before interacting with the web

Hacker for Hire

Hire a Professional Hacker - Certified Ethical Hackers ...

Hire Hackers Shop hacking tools today! Being an organization that's fully committed to solving every problem in the hacking community, we offer all kinds of hacking services. Furthermore, once you've successfully signed up with one of our hackers for any project, we'll give direct and unlimited access to our entire store to shop for ...

27 Best Freelance Hackers For Hire in March 2022 - Upwork

Hacker For Hire. Hire the #1 Hire a Hacker Cyber Service ...

44

Determining the Operating System



SHODAN search engine lets you find **connected devices** (routers, servers, IoT, etc.) using a variety of filters

Censys search engine provides a full view of every **server and device** exposed to the Internet

45

Competitive Intelligence Gathering



- Competitive intelligence gathering is the process of **identifying, gathering, analyzing, verifying**, and using information about your competitors from resources, such as the Internet
- Competitive intelligence is **non-interfering** and **subtle in nature**



Sources of Competitive Intelligence

- Company websites and employment ads
- Search engines, Internet, and online database
- Press releases and annual reports
- Trade journals, conferences, and newspapers
- Patent and trademarks
- Social engineering employees
- Product catalogs and retail outlets
- Analyst and regulatory reports
- Customer and vendor interviews
- Agents, distributors, and suppliers

46

Competitive Intelligence Gathering (Cont'd)



When Did this Company Begin? How Did it Develop?

Information Resource Sites

- EDGAR Database**
<https://www.sec.gov/edgar.shtml>
- D & B Hoovers**
<https://www.dnb.com>
- LexisNexis**
<https://www.lexisnexis.com>
- Business Wire**
<http://www.businesswire.com>

What Are the Company's Plans?

Information Resource Sites

- MarketWatch**
<https://www.marketwatch.com>
- The Wall Street Transcript**
<https://www.twst.com>
- Euromonitor**
<https://www.euromonitor.com>
- Experian**
<https://www.experian.com>

What Expert Opinions Say About the Company?

Information Resource Sites

- SEMRush**
<https://www.semrush.com>
- ABI/INFORM Global**
<https://www.proquest.com>
- SimilarWeb**
<https://www.similarweb.com>
- SERanking**
<https://seranking.com>

47

LO#05: Use Different Techniques for Website Footprinting

48

Website Footprinting



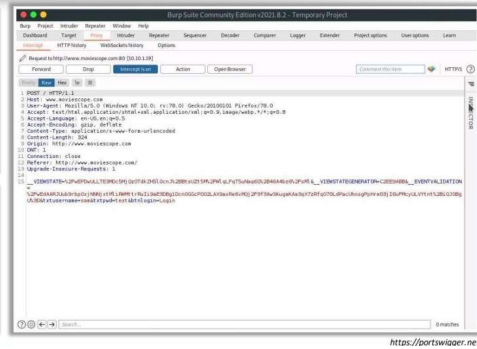
- Website footprinting refers to the **monitoring and analysis of the target organization's website** for information

Browsing the target website may provide the following information:

- Software used and its version
- Operating system used and its scripting platform
- Sub-directories and parameters
- Filename, path, database field name, or query
- Technologies used
- Contact and CMS details

Attackers use **Burp Suite**, **Zaproxy**, **Wappalizer**, **CentralOps**, **Website Informer**, etc. to view headers that provide the following information:

- Connection status and content-type
- Accept-Ranges and Last-Modified
- X-Powered-By information
- Web server in use and its version



<https://portswigger.net>

49

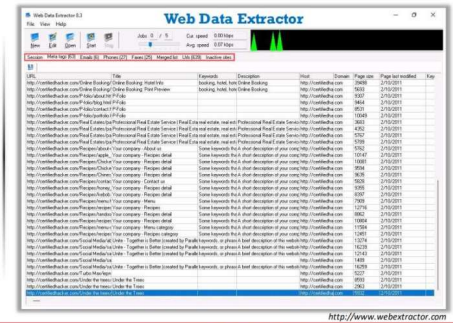
Website Footprinting using Web Spiders



- Web spiders, such as **Web Data Extractor** and **ParseHub**, perform automated searches on the target website and collect specified information, such as **employee names** and **email addresses**
- Attackers use the collected information to perform **footprinting** and **social engineering attacks**

User-Directed Spidering

- Attackers use **standard web browsers** to walk through the target website functionalities
- The incoming and outgoing **traffic of the target website is monitored** and analyzed by tools that include features of both a web spider and an intercepting proxy
- Attackers use tools such as **Burp Suite** and **WebScarab** to perform user-directed spidering



<http://www.webextractor.com>

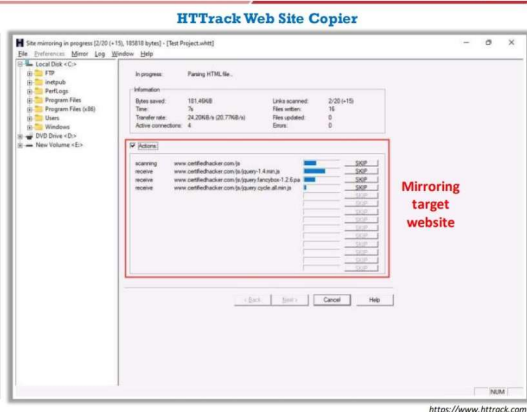
50

Mirroring Entire Website



- Mirroring an entire website onto a local system enables an attacker to browse website offline; it also assists in finding **directory structure** and other valuable information from the mirrored copy without sending multiple requests to web server

- Web mirroring tools, such as HTTrack Web Site Copier, and Cyotek WebCopy, allow you to **download a website to a local directory**, recursively building all directories, HTML, images, flash, videos, and other files from the server to your computer



<https://www.httrack.com>

51

LO#06: Use Different Techniques for Email Footprinting

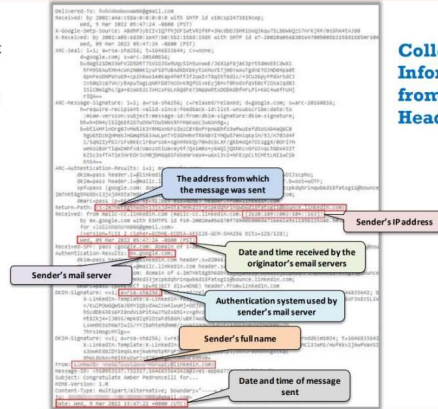
52

Tracking Email Communications



- Email tracking is used to **monitor the delivery of emails** to an intended recipient
- Attackers track emails to **gather information about a target recipient**, such as IP addresses, geolocation, browser and OS details, to build a hacking strategy and perform social engineering and other attacks

Collecting Information from Email Header



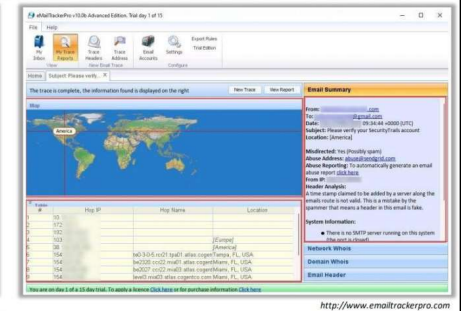
53

Email Tracking Tools



- Email tracking tools, such as eMailTrackerPro, Infoga, Mailtrack, and PoliteMail, allow an attacker to **track an email and extract information**, such as sender identity, mail server, sender's IP address, and location
- eMailTrackerPro analyzes email headers and reveals information, such as **sender's geographical location** and IP address

<https://github.com>



<http://www.emailtrackerpro.com>

54

LO#07: Use Different Techniques for Whois Footprinting



Whois Lookup



Whois databases are maintained by **Regional Internet Registries** and contain **personal information of domain owners**

Whois query returns

- Domain name details
- Contact details of domain owners
- Domain name servers
- NetRange
- When a domain was created
- Expiry records
- Last updated record

Information obtained from Whois database assists an attacker to

- Gather personal information that assists in social engineering
- Create a map of the target organization's network
- Obtain internal details of the target network



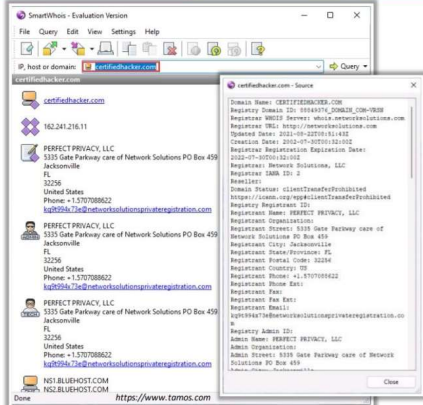
Regional Internet Registries (RIRs)



55

56

Whols Record for CertifiedHacker.com	
— Domain Profile	
Registrar	PERFECT PRIVACY, LLC
Registrar Country	us
Registrar Network	Network Solutions, LLC
IANA ID	2
URL	http://www.networksolutions.com
WhoIs Server	whois.networksolutions.com
Domain Name	certifiedhacker.com
Domain Name Server	ns1.1877282662.com
Registrar Status	clientTransferProhibited
Dates	7,184 days old
	Created on 2002-07-29
	Expires on 2022-07-29
	Updated on 2021-08-22
Name Servers	NS1.BLUEHOST.COM (us.2.681.575 domains)
	NS2.BLUEHOST.COM (us.2.681.575 domains)
Web Techs	PERFECT PRIVACY, LLC
	5235 State Parkway, Suite of Network Solutions PO Box 459, Jacksonville, FL 32256, us
	kuf9p94@networksolutions.com
	http://www.networksolutions.com/hostingregistration.com
IP Address	162.241.216.11 - 1,745 other sites hosted on this server
IP Location	us - Utah - Provo - Unified World
ASN	AS52623635 US (registered Oct 09, 2013)
Domain Status	Registered And Active Website
IP History	13 changes on 13 unique IP addresses over 16 years
Registrar History	3 registers with 2 drops
Hosting History	6 changes on 4 unique name servers over 19 years



CEH
Certified Ethical Hacker

LO#08: Use Different Techniques for DNS Footprinting

CEH
Certified Ethical Hacker

IP2Location

- 📍 IP geolocation lookup tools, such as **IP2Location** and **IP Location Finder**, help to collect IP geolocation information about the target, which in turn helps attackers in **launching social engineering attacks**, such as spamming and phishing



IP Address	207.46.232.182
Country	 Singapore [SG] ⓘ
Region	Singapore
City	Singapore
Coordinates of City	1.289670, 103.850070 (1°17'23"N 103°51'0"E)
ISP	Microsoft Corporation
Local Time	10 Mar, 2022 87:54 PM (UTC +08:00)
Domain	microsoft.com
Net Speed	(COMP) Company/T1
IDD & Area Code	(65) 06
ZIP Code	179431
Weather Station	Singapore (SNOO0006)

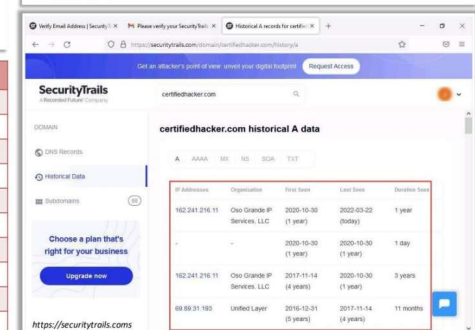
<https://www.ip2location.com>

CER
Certified Ethical Recruitment

- DNS records provide important information about the **location and types of servers**
- Attackers can gather DNS information to **determine key hosts in the network** and can perform social engineering attacks

- 📁 Attackers query DNS servers using DNS interrogation tools, such as SecurityTrails, NSLOOKUP, and DNS Records, to **retrieve the record structure** that contains information about the target DNS

Record Type	Description
A	Points to a host's IP address
MX	Points to domain's mail server
NS	Points to host's name server
CNAME	Canonical naming allows aliases to a host
SOA	Indicate authority for domain
SRV	Service records
PTR	Maps IP address to a hostname
RP	Responsible person
HINFO	Host information record includes CPU type and OS
TXT	Unstructured text records



<https://securitytrails.com>

60

Reverse DNS Lookup

- Attackers perform a reverse DNS lookup on IP ranges in an attempt to **locate a DNS PTR record** for those IP addresses
- Attackers use various tools, such as **DNSRecon** and **Reverse Lookup** to perform the reverse DNS lookup on the target host

SuperTool Beta?

Reverse Lookup

ptr:162.241.216.11

Type	IP Address	Domain Name	TTL
TypePTR	IP Address:162.241.216.11	Domain Name:box5331.bluehost.com	TTL:24 hrs

Status: NameDNS Record Published Result: ResponseDNS Record found

Empty diag. Submitted. Submit tool. Site propagation. Reported by nat.unifiedlayer.com on 3/10/2022 at 7:22:21 AM (UTC -4). Just for you. Transcript

<https://mxttoolbox.com>

```

attacker@parrot:~$ sudo dnsrecon -i 162.241.216.11 -w 162.241.216.255
Performing reverse lookup from 162.241.216.11 to 162.241.216.255
PTR 162.241.216.2-unifiedlayer.com 162.241.216.1
PTR 162.241.216.1-unifiedlayer.com 162.241.216.1
PTR 162.241.216.5-unifiedlayer.com 162.241.216.2
PTR 162.241.216.4-unifiedlayer.com 162.241.216.4
PTR 162.241.216.9-unifiedlayer.com 162.241.216.9
PTR 162.241.216.6-unifiedlayer.com 162.241.216.6
PTR 162.241.216.8-unifiedlayer.com 162.241.216.8
PTR 162.241.216.7-unifiedlayer.com 162.241.216.7
PTR 162.241.216.10-unifiedlayer.com 162.241.216.10
PTR 162.241.216.3-unifiedlayer.com 162.241.216.3
PTR 162.241.216.11-unifiedlayer.com 162.241.216.11
PTR 162.241.216.12-unifiedlayer.com 162.241.216.12
PTR 162.241.216.13-unifiedlayer.com 162.241.216.13
PTR 162.241.216.14-unifiedlayer.com 162.241.216.14
PTR 162.241.216.15-unifiedlayer.com 162.241.216.15
PTR 162.241.216.16-unifiedlayer.com 162.241.216.16
PTR 162.241.216.17-unifiedlayer.com 162.241.216.17
PTR 162.241.216.18-unifiedlayer.com 162.241.216.18
PTR 162.241.216.19-unifiedlayer.com 162.241.216.19
PTR 162.241.216.20-unifiedlayer.com 162.241.216.20
PTR 162.241.216.21-unifiedlayer.com 162.241.216.21
PTR 162.241.216.22-unifiedlayer.com 162.241.216.22
PTR 162.241.216.23-unifiedlayer.com 162.241.216.23
PTR 162.241.216.24-unifiedlayer.com 162.241.216.24
PTR 162.241.216.25-unifiedlayer.com 162.241.216.25
PTR 162.241.216.26-unifiedlayer.com 162.241.216.26
PTR 162.241.216.27-unifiedlayer.com 162.241.216.27
PTR 162.241.216.28-unifiedlayer.com 162.241.216.28
PTR 162.241.216.29-unifiedlayer.com 162.241.216.29
PTR 162.241.216.30-unifiedlayer.com 162.241.216.30
  
```

<https://github.com>

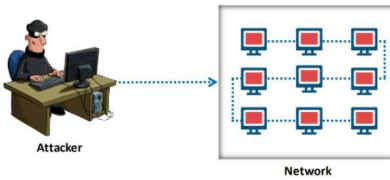
61

L0#09: Use Different Techniques for Network Footprinting

62

Locate the Network Range

- Network range information assists attackers in creating a **map of the target network**
- One can find the **range of IP addresses** using **ARIN whois database search tool**
- One can also find the range of IP addresses and the subnet mask used by the target organization from **Regional Internet Registry (RIR)**



Network: NET-207-46-0-0-1

Source Registry	ARIN
Net Range	207.46.0.0 - 207.46.255.255
CGN	NO
Name	MICROSOFT-IP-GLOBE-NET
Handle	NET-207-46-0-0-1
Parent	NET-207-0-0-0-0
Net Type	DIRECT ALLOCATION
Origin AS	not provided
Registration	Net 10 MAY 1997 20:00:00 GMT (May 11 1997 local time)
Last Changed	Net 10 MAY 2021 03:00:00 GMT (May 10 2021 local time)
Comments	https://www.arin.net/whois/NET-207-46-0-0-1
Alternate	https://www.arin.net/whois/NET-207-46-0-0-1
Port 43 Whois	whois.arin.net

Source Registry	ARIN
Kind	Org
Full Name	Microsoft Corporation
Handle	MSFT
Address	One Microsoft Way Redmond WA 98073 United States
Registration	Net 10 JUL 1986 04:00:00 GMT (Jul 10 1986 local time)
Last Changed	Net 10 OCT 2021 21:00:00 GMT (Oct 14 2021 local time)
Comments	To report suspected security issues specific to traffic emanating from Microsoft online services, including the distribution of malicious content or other illicit or illegal material through a Microsoft online service, please submit reports to: https://port.microsoft.com

Network Whois Record
Queried
search.arin.net with
"207.46.232.182"

63

Traceroute

- Traceroute programs work on the concept of **ICMP protocol** and **use the TTL field in the header of ICMP packets** to discover the routers on the path to a target host

ICMP Traceroute

```

Microsoft Windows [Version 10.0.22000.489]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>tracert 216.239.36.10

Tracing route to ms.google.com [216.239.36.10]
over a maximum of 30 hops:

  0  0 ms  0 ms  0 ms  10.10.1.2
  1  1 ms  1 ms  1 ms  192.168.100.6
  2  1 ms  1 ms  1 ms  192.168.100.6
  3  2 ms  2 ms  2 ms  10.140.226.249
  4  2 ms  2 ms  2 ms  10.140.226.249
  5  3 ms  3 ms  3 ms  10.140.226.249
  6  0 ms  0 ms  0 ms  10.140.226.249
  7  0 ms  0 ms  0 ms  10.140.226.249
  8  0 ms  0 ms  0 ms  10.140.226.249
  9  0 ms  0 ms  0 ms  10.140.226.249
 10  0 ms  0 ms  0 ms  10.140.226.249
 11  0 ms  0 ms  0 ms  10.140.226.249
 12  0 ms  0 ms  0 ms  10.140.226.249
 13  0 ms  0 ms  0 ms  10.140.226.249
 14  0 ms  0 ms  0 ms  10.140.226.249
 15  0 ms  0 ms  0 ms  10.140.226.249
  
```

TCP Traceroute

```

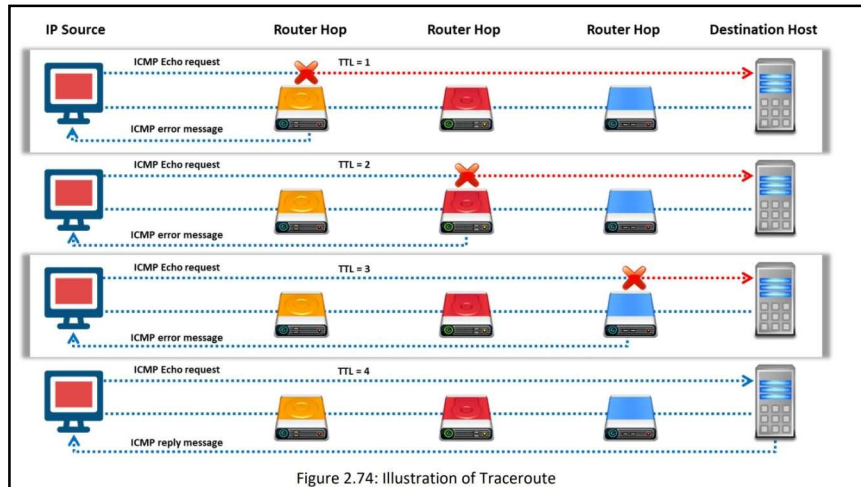
Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ sudo tcping www.google.com
[sudo] password for attacker:
tcping:
tcping www.google.com
tcping: www.google.com:80: 100% success, 0 hops, 0 byte packets
  0  10.10.1.2 (10.10.1.2)  3.499 ms  3.499 ms  9.107 ms
  1  192.168.100.6 (192.168.100.6)  17.382 ms  19.869 ms  20.324 ms
  2  192.168.100.6 (192.168.100.6)  17.382 ms  19.869 ms  20.324 ms
  3  10.140.226.249 (10.140.226.249)  24.434 ms  25.957 ms  27.143 ms
  4  10.140.226.249 (10.140.226.249)  24.434 ms  25.957 ms  27.143 ms
  
```

UDP Traceroute

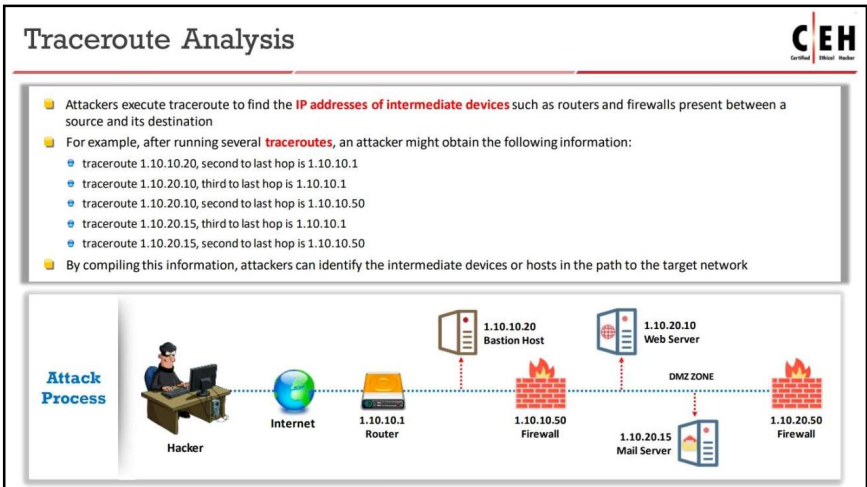
```

Parrot Terminal
File Edit View Search Terminal Help
[attacker@parrot:~]$ sudo udping www.google.com
[sudo] password for attacker:
udping:
udping www.google.com
udping: www.google.com:80: 100% success, 0 hops, 0 byte packets
  0  10.10.1.2 (10.10.1.2)  1.378 ms  1.442 ms  1.314 ms
  1  192.168.100.6 (192.168.100.6)  1.358 ms  1.723 ms  1.937 ms
  2  192.168.100.6 (192.168.100.6)  2.654 ms  2.685 ms  3.937 ms
  3  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  4  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  5  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  6  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  7  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  8  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  9  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 10  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 11  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 12  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 13  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 14  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
 15  10.140.226.249 (10.140.226.249)  4.444 ms  4.444 ms  4.444 ms
  
```

64



65



66

LO#10: Demonstrate Footprinting through Social Engineering

67

Footprinting through Social Engineering

Social engineering is an art of exploiting human behaviour to **extract confidential information**.

Social engineers depend on the fact that **people are unaware** of their valuable information and are careless about protecting it.

Social engineers attempt to gather

- Credit card details and social security number
- Usernames and passwords
- Security products in use
- Operating systems and software versions
- Network layout information
- IP addresses and names of servers

Social engineering techniques include

- Eavesdropping
- Shoulder surfing
- Dumpster diving
- Impersonation

68

Collecting Information Using Eavesdropping, Shoulder Surfing, Dumpster Diving, and Impersonation



Eavesdropping

- Unauthorized listening of conversations or reading of messages
- It is the **interception of any form of communication**, such as audio, video, or text



Shoulder Surfing

- Secretly observing the target to gather critical information, such as **passwords**, **personal identification number**, account numbers, and credit card information



Dumpster Diving

- Looking for treasure in someone else's trash
- It involves the collection of **phone bills**, **contact information**, **financial information**, operations-related information, etc. from the target company's trash bins, printer trash bins, user desk for sticky notes, etc.



Impersonation

- Pretending to be a **legitimate or authorized person** and using the phone or other communication medium to mislead targets and trick them into revealing information



69



LO#11: Use Various Footprinting Tools

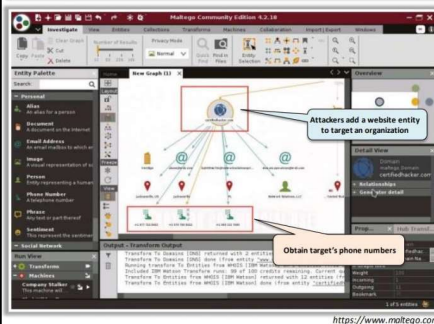
70

Footprinting Tools: Maltego and Recon-ng



Maltego

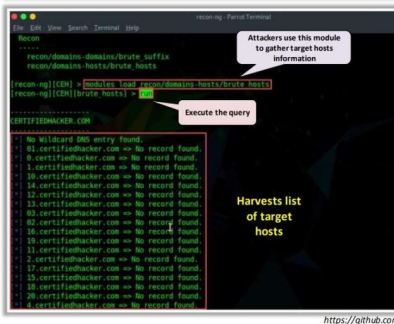
Maltego can be used to determine the **relationships and real world links** between people, groups of people, organizations, websites, Internet infrastructure, documents, etc.



<https://www.maltego.com>

Recon-ng

Recon-ng is a **Web Reconnaissance framework** with independent modules and database interaction, which provides an environment in which open source, web-based reconnaissance can be conducted



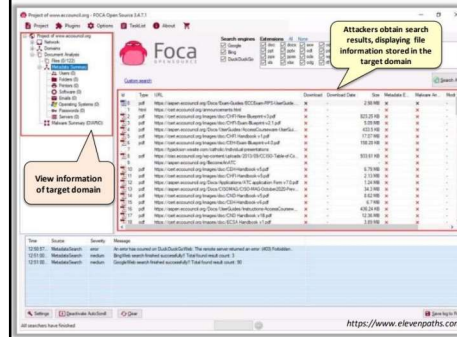
<https://github.com>

71

Footprinting Tools: FOCA and OSRFramework

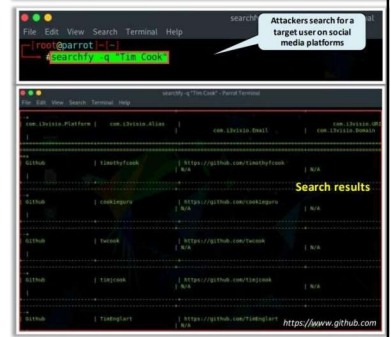


FOCA (Fingerprinting Organizations with Collected Archives) is a tool used mainly to find metadata and hidden information in the documents it scans



<https://www.elevenpaths.com>

OSRFramework includes applications related to username checking, DNS lookups, information leaks research, deep web search, regular expressions extraction, etc.



<https://www.github.com>

72

Reconnaissance Tools (Cont'd)

IMCPTraceroute

```

C:\Users\Nimble>tracert 216.239.36.10

Tracing route to ms3.google.com [216.239.36.10]
over a maximum of 30 hops:
  0  <1 ms  <1 ms  <1 ms  10.10.10.2
  1  4 ms    8 ms   14 ms  115.240.109.01
  2  13 ms   13 ms  11 ms  115.255.255.226
  3  14 ms   13 ms  13 ms  74.125.51.2
  4  27 ms   25 ms  16 ms  108.170.253.121
  5  47 ms   40 ms  40 ms  72.14.233.129
  6  82 ms   83 ms  83 ms  72.14.239.212
  7  93 ms   93 ms  93 ms  209.05.245.103
  8  91 ms   91 ms  92 ms  72.14.233.35
  9  *      *      *      Request timed out.
 10  *      *      *      Request timed out.
 11  *      *      *      Request timed out.
 12  *      *      *      Request timed out.

```



TCPTraceroute

```

root@parrot:~# traceroute www.google.com
traceroute to www.google.com (172.217.163.164), 30 hops max, 60 byte packets
 1  10.10.10.2 (10.10.10.2)  0.312 ms  0.172 ms  0.207 ms
 2  maa5s05-in-fd.1e108.net (172.217.163.164)  <syn,ack>  17.775 ms  17.367 ms  17.491 ms

```

UDPTraceroute

```

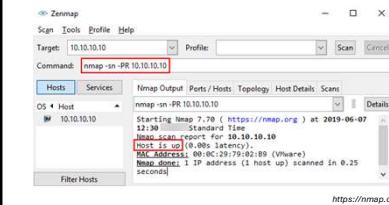
root@parrot:~# traceroute www.google.com
traceroute to www.google.com (172.217.163.164), 30 hops max, 60 byte packets
 1  10.10.10.2 (10.10.10.2)  0.269 ms  0.189 ms  0.196 ms
 2  *      *      *      Request timed out.
 3  *      *      *      Request timed out.
 4  *      *      *      Request timed out.
 5  *      *      *      Request timed out.
 6  *      *      *      Request timed out.
 7  *      *      *      Request timed out.
 8  *      *      *      Request timed out.
 9  *      *      *      Request timed out.
10  *      *      *      Request timed out.
11  *      *      *      Request timed out.
12  *      *      *      Request timed out.

```

Scanning Tools

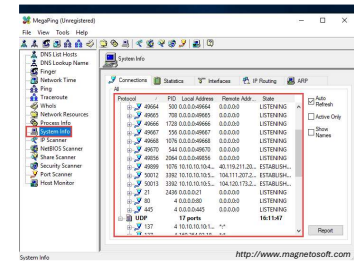
Nmap

Use Nmap to extract information such as **live hosts** on the network, open ports, services (application name and version), types of packet filters/ firewalls, as well as operating systems and versions used



MegaPing

Includes scanners such as Comprehensive Security Scanner, **Port scanner** (TCP and UDP ports), IP scanner, NetBIOS scanner, and Share Scanner



77

78

Scanning Tools (Cont'd)

Unicornscan

In Unicornscan, the OS of the target machine can be identified by **observing the TTL values** in the acquired scan result

```

root@parrot:~# unicornscan 10.10.10.10 -iv
Running 10.10.10.10/32 mode 'TCPScan' ports: 7,9,11,13,15,17,19,21,23,25,27,31,42,46,50,52,
65,67,70,79,81,86,90,96,100,105,107,110,111,113,115,116,118,119,120,125,128,135,137,139,143,150,161,166,
174,177,179,181,199,202,204,206,209,210,213,220,345,346,347,369,372,389,400,407,422,4
12,445,487,500,512,514,517,518,500,525,533,538,540,554,563,567,610,612,631,634,636,642,
653,655,657,666,706,750,752,765,779,808,875,901,923,941,946,992,995,1001,1023,1030,1090,
1210,1214,1234,1281,1334,1349,1352,1423,1425,1433,1434,1524,1525,1645,1646,1648,1701,1
110,1710,1720,1723,1750,1812,1813,2048,2050,2101,2106,2140,2150,2233,2235,2245,2443,24
0,2431,2432,2433,2583,2628,2776,2777,2908,2909,3050,3130,3150,3232,3300,3389,3450,3495,
3542,3545,3632,3690,3801,4000,4100,4211,4507,4599,5042,5130,5139,5151,5222,5509,55
88,5354,5355,5422,5425,5432,5593,5555,5556,5679,6068,6069,6346,6347,6541,6544,6789,6888,
6666,6670,7000,7020,7100,7803,8079,8082,8088,8787,8879,8880,9101,9103,9325,9355,1
0000,10002,10007,10009,10083,10107,10404,11203,15545,17003,17009,18753,20011,2000
2,21554,22273,26274,27374,27444,27573,31330,31338,31767,31769,31780,31791,32668,32767,3
706,31890,47282,49081,54520,54521,57541,58000,58009,58060,59211,60000,60006,61000,61334
61560,61601,61645,63000,63009,63429,65000,65500,65538,65539, 995, 300
Using interface(s) eth0
Running 1.000-00 total hosts with 3.38e+02 total packets, should take a little longer t
han 3 seconds
TCP open 10.10.10.10/2100 TTL 128
TCP open 10.10.10.10/80 TTL 128
TCP open 10.10.10.10/445 TTL 128
TCP open 10.10.10.10/339 TTL 128
TCP open 10.10.10.10/115 TTL 128
TCP open 10.10.10.10/3308 TTL 128
TCP open 10.10.10.10/10 TTL 128

```

Possible OS is Windows



Hping2/Hping3
<https://www.hping.org/>



NetScanTools Pro
<https://www.netscan-tools.com/>



SolarWinds Port Scanner
<https://www.solarwinds.com/>



PRTG Network Monitor
<https://www.paessler.com/>

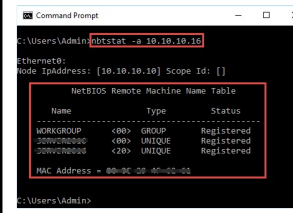


OmniPeek Network Protocol Analyzer
<https://www.flir.no/>

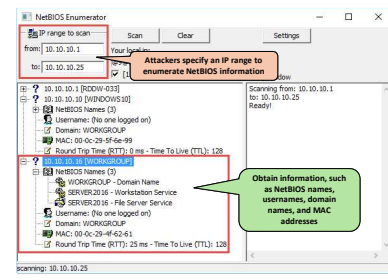
Enumeration Tools



The nbtstat utility in Windows displays NetBIOS over **TCP/IP** (NetBT) **protocol statistics**, **NetBIOS name tables** for both the local and remote computers, and the **NetBIOS name cache**



NetBIOS Enumerator helps to enumerate details, such as **NetBIOS names**, **Usernames**, **Domain names**, and **MAC addresses**, for a given range of IP addresses



Other NetBIOS Enumeration Tools:

Global Network Inventory
<http://www.magnetosoft.com/>

Advanced IP Scanner
<https://www.advanced-ip-scanner.com/>

Hyena
<https://www.systemtools.com/>

Nsauditor Network Security Auditor
<https://www.nsauditor.com/>

79

80